

Warsaw, May 16, 2023

Decision

DKN.5131.56.2022

Based on Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2022, item 2000, as amended), Article 7 § 1 and Article 60, Article 102 § 1 point 1 and § 3, and Article 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), as well as Article 57 § 1 letters a) and h), Article 58 § 2 letters d) and i), Article 83 § 1 – 3, Article 83 § 4 letter a) in connection with Article 24 § 1, Article 25 § 1, and Article 32 § 1 and 2, and Article 83 § 5 letter a) in connection with Article 5 § 1 letter f) and Article 5 § 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by the Mayor of the City of Z. (City Office of Z., ul. [...]), the President of the Personal Data Protection Office, stating the violation by the Mayor of the City of Z. (City Office of Z., ul. [...]), Article 5 § 1 letter f), Article 5 § 2, Article 24 § 1, Article 25 § 1, and Article 32 § 1 and 2 of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons in relation to the processing of personal data and on the free movement of such data and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 05.04.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 04.03.2021, p. 35), hereinafter referred to as Regulation 2016/679, consisting of the selection of ineffective security measures for the IT system used for processing personal data and the lack of appropriate testing, measuring, and assessing the effectiveness of technical and organizational measures intended to ensure the security of processed personal data in the IT systems covered by the violation, particularly regarding vulnerabilities, errors, and their possible consequences for these systems and the actions taken to minimize the risk of their occurrence: 1) orders the Mayor of the City of Z. to adjust the processing operations to the provisions of Regulation 2016/679 by implementing appropriate technical and organizational measures to ensure regular testing, measuring, and assessing the effectiveness of technical and organizational measures intended to ensure the security of processing, within 30 days from the date of delivery of this decision, 2) imposes on the Mayor of the City of Z. (City Office of Z., ul. [...]) for the violation of the provisions of Article 5 § 1 letter f), Article 5 § 2, Article 25 § 1, and Article 32 § 1 and 2 of Regulation 2016/679 an administrative fine in the amount of 30,000 zlotys (in words: thirty thousand zlotys).

Justification

The Mayor of the City of Z. (City Office of Z., ul. [...]), also referred to as the Administrator or Mayor, (...) in June 2022 reported to the President of the Personal Data Protection Office, hereinafter also referred to as the President of UODO, a personal data breach that occurred in (...) June 2022. The Administrator indicated that the personal data breach consisted of: "(...) blocking access through the internal network to the server by end users (...)". In the further part of the form "Notification of a Personal Data Breach," the Mayor indicated that "(...) malicious software L. placed a text file in each folder with information about the ransom (...)". The breach concerned approximately 9,400 individuals. The Administrator indicated that the categories of personal data that were breached included: surnames and first names, parents' names, date of birth, bank account number, residential or stay address, PESEL number, email address, data regarding earnings and/or owned assets, mother's maiden name, phone number, image. The President of UODO conducted an explanatory proceeding regarding the reported breach (registered under reference: [...]), and then initiated ex officio on (...) November 2022 an administrative proceeding regarding the possibility of the Mayor, as the data administrator, violating the obligations arising from the provisions of Article 5 § 1 letter f), Article 5 § 2, Article 24 § 1, Article 25 § 1, and Article 32 § 1 and 2 of Regulation 2016/679. The President of UODO, as a result of the conducted explanatory proceeding regarding the reported personal data breach and the administrative proceeding, established the following factual state. 1) By letter dated (...) June

2022, the Administrator provided the supervisory authority with explanations, in which he indicated, among other things, that: - the personal data breach was caused by a ransomware attack due to the exploitation of a vulnerability existing in the IT system, - it is likely that there was no loss of confidentiality of personal data, but as of the date of the response, he was unable to confirm this, - he did not contact the Internet service provider to inquire whether there had been unjustified data retrieval from the City Office in Z., - work was ongoing to recover data from the backup (up to the date of the letter dated [...] June 2022).

****Administrator recovered approximately 80% of the data**,**

conducted an analysis of all processes of personal data processing, including the process in which the breach occurred (the risk analysis was attached to the aforementioned letter), - the schedule for creating backups was specified in (...)

the Order of the Mayor of the City of Z. No. (...) dated (...) January 2019 regarding (...), - the server on which the backups were stored failed, - the server is automatically updated daily with virus signatures (the IT specialist of the City Office of Z. checks whether the update has occurred).

Furthermore, in the letter dated (...) June 2022, the Administrator listed the technical and organizational measures he implemented before the occurrence of the breach. The Mayor indicated that in terms of the organizational measures applied, he conducted employee training and introduced: - a risk management and cybersecurity procedure, - an IT system management instruction, - a personal data protection regulation, - an information security and personal data protection policy, - a risk management policy for data security loss.

In turn, regarding the technical measures applied before the occurrence of the breach, the Administrator explained that: "(...) a) Access to the server's operating system is secured through an authentication process using an individual user ID and password; b) System F. was used to protect access to the computer network; c) Various tools are used to protect against malicious software, such as: a. vulnerability scanner; b. event monitoring system; c. antivirus protections; d. analysis and protection of connections to websites; d) Backups are created. e) Antivirus software (...)."

Additionally, in the letter dated (...) June 2022, the Mayor indicated that after the breach was identified, he took the following actions: - disconnected the server from the network, - scanned computers and the server with antivirus software, - initiated the procedure for purchasing X, equipment, and software for performing automatic backups.

Along with the letter dated (...) June 2022, the Administrator provided, among others, "Sheet (...)."

2) In a letter dated (...) July 2022, the Administrator indicated, among others, that "(...) software Y. was purchased on [...] 07.2022 and installed on all workstations. Furthermore, we are in the process of purchasing: Server D. Firewall X. F., license and support for 2 years UPS for server room A. UPS power supply T. Server type H. for backup Q. Backup enforcement software F. Planned implementation August - September 2022. On [...] 07.2022, all employees of the Office underwent cybersecurity training. We are also in the process of developing and updating procedures concerning: performing and verifying/testing backups; updating software; restoring the IT system; conducting risk analysis; schedule of control/audit activities; (planned implementation date August 2022.) (...)."

Moreover, in the aforementioned letter, the Mayor indicated that: - the software used for the ransomware attack is L., - the vulnerability of the IT system exploited to carry out the attack was an outdated virus database, - at the time of the breach, the server had software R., W. with patches installed, - data is being recovered from backups and paper documentation (the reason for the difficulties in their recovery is encrypted backups), - the planned date for full data recovery is August 2022, - backups were also encrypted, - the Administrator is recovering backups from the years 2019, 2020, 2021.

To the letter dated (...) July 2022, the Administrator attached, among others: - "Attachment to the order (...) of the Mayor of the City of Z. dated (...) January 2019. List (...)", - "Order No. (...) of the Mayor of the City of Z. dated (...) January 2019 regarding (...)."

3) In a letter dated (...) August 2022, the Administrator explained that "(...) he contacted the entity providing internet access services. The information received from the operator indicates that in the days preceding the attack (until the time of disconnection from the network), no increased network traffic suggesting data exfiltration was observed (...) After analyzing the events related to the

ransomware attack, the administrator concluded that there was no loss of confidentiality or integrity of personal data. The recovered data did not undergo unauthorized changes, maintaining its consistency, accuracy, and reliability (...) The program with the outdated virus database is M. (...) Data was recovered from backups from the years 2019, 2020, and 2021. (...)” Along with the aforementioned letter, the Mayor attached: - “Sheet (...)” – created after the occurrence of the personal data breach, - confirmation of purchase (invoice) “Y. – the license purchase is valid for 3 years for 63 stations”, - confirmation of cybersecurity training for personnel, - “Instruction (...)” constituting an attachment to the order (...) of the Mayor of the City of Z. dated (...) August 2022, - “Schedule (...)” dated (...) August 2022.

4) In a letter dated (...) December 2022, the Administrator explained that all data encrypted as a result of the ransomware attack had been recovered by (...) August 2022. The data was restored from backups and paper documentation. Furthermore, the Mayor indicated that “(...) he implemented the following organizational and technical measures to minimize

****Risks Associated with Breach of Personal Data Protection****

1. A position was created for the employment of an additional IT specialist (from [...].08.2022);
2. By the Order of the Mayor of the City of Z. No. (...), an instruction for Managing the IT System was implemented, which includes, among others: procedures for creating backup copies, verification and testing of these copies, rules for using the internet, email, creating and changing passwords for systems;
3. IT specialists [2 persons] exercise constant supervision over the course of antivirus system updates and the backup system, including testing copies;
4. All passwords were changed, and passwords for all accounts, including administrative accounts, were modified;
5. IT specialists of the Office participate in online training conducted by experts from the Scientific and Academic Computer Network of the National Research Institute;
6. As part of a task commissioned by the Minister of Digitization titled , the management staff of the Office [Mayor, Deputy Mayor, Secretary, Treasurer, Head of the Civil Registry Office] participated on [...].11.2022 in individual training on cybersecurity;
7. Antivirus software Y. was implemented on all workstations [by [...].07.2022];
8. A procurement procedure is ongoing for the equipment listed below:
 - Server D.;
 - Network Firewall X. F., licenses and support for 2 years;
 - UPS for server room A.;
 - Server type H. for backup Q.;

On [...].11.2022, the 5th procurement procedure for the purchase of the aforementioned equipment was announced – previous ones were canceled due to excessive price or lack of offers. In the current procedure, offers can be submitted until [...].12.2022, while the delivery date was set for 90 days from the date of signing the contract (...).”

5) In response to the letter from the President of the UODO dated (...) March 2023, informing the Mayor about the collection of evidence sufficient to issue an administrative decision, the Administrator in a letter dated (...) March 2023 indicated that “(...) 1. Access to all data has been obtained; 2. Based on the collected evidence, no personal data breach was identified; 3. No reports from data subjects indicating damage due to the breach were recorded; 4. The equipment and software serving the security of processed personal data have been modernized (equipment mentioned in previous letters to PUODO was purchased and mostly implemented); 5. Procedures ensuring high standards of personal data processing security in IT systems have been implemented; 6. Staff training on personal data protection and cybersecurity has been conducted; 7. As part of regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of processing, cyclical audits and risk analyses are conducted (...)”.

The supervisory authority assessed the evidence for its credibility and evidential value. The President of the UODO deemed the vast majority of the evidence submitted by the Administrator to be credible.

This is supported by the fact that the Mayor's explanations are mostly logical, coherent, and correlate with the entirety of the evidence. The President of the UODO did not believe the Mayor's explanations regarding the virus database update by the IT specialist contained in the letter from (...) June 2022. The reason for denying the credibility of the Mayor's explanations in this regard is that they contradict the further explanations of the Administrator concerning this issue. As it follows from the entirety of the collected evidence, the cause of the ransomware attack was an outdated virus database – which the Administrator himself admitted in further explanations, indicating in a letter from (...) July 2022 that the vulnerability of the IT system exploited to carry out the attack was the outdated virus database.

In this factual state, after reviewing all the collected evidence in the case, the President of the Personal Data Protection Office considered the following:

According to Article 34 of the Act of May 10, 2018 on Personal Data Protection (Journal of Laws of 2019, item 1781) - hereinafter referred to as the Act of May 10, 2018, the President of the UODO is the competent authority in the matter of data protection and the supervisory authority within the meaning of Regulation 2016/679. Pursuant to Article 57(1)(a) and (h) of Regulation 2016/679, without prejudice to other tasks specified under this regulation, each supervisory authority in its territory monitors and enforces the application of this regulation and conducts proceedings regarding breaches of this regulation, including based on information received from another supervisory authority or another public authority.

Article 5 of Regulation 2016/679 formulates principles regarding the processing of personal data that must be respected by all administrators, i.e., entities that independently or jointly with others determine the purposes and means of processing personal data. According to Article 5(1)(f) of Regulation 2016/679, personal data must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ("confidentiality and integrity"). Furthermore, according to Article 5(2) of Regulation 2016/679, the administrator is... responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate such compliance ("accountability"). The specification of the confidentiality principle referred to in Article 5(1)(f) of Regulation 2016/679 is provided by further provisions of this legal act. According to Article 24(1) of Regulation 2016/679, taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying likelihood and severity, the controller implements appropriate technical and organizational measures to ensure that processing is performed in accordance with this Regulation and to be able to demonstrate it. These measures are reviewed and updated as necessary.

Pursuant to Article 25(1) of Regulation 2016/679, taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying likelihood of occurrence and severity arising from processing, the controller—both when determining the means of processing and during the processing itself—implements appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement data protection principles, such as data minimization, and to provide the necessary safeguards for processing to meet the requirements of this Regulation and protect the rights of data subjects.

From the content of Article 32(1) of Regulation 2016/679, it follows that the controller is obliged to apply technical and organizational measures corresponding to the risk of infringement of the rights and freedoms of natural persons with varying likelihood of occurrence and severity of threat. The provision specifies that when deciding on technical and organizational measures, one must take into account the state of the art, the cost of implementation, the nature, scope, context, and purposes of processing, and the risk of infringement of the rights or freedoms of natural persons with varying likelihood of occurrence and severity. The cited provision indicates that determining appropriate technical and organizational measures is a two-step process. First, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria specified in Article 32(1) of Regulation 2016/679, and then to establish what technical and organizational measures will

be appropriate to ensure a level of security corresponding to that risk. These determinations, where appropriate, should include measures such as pseudonymization and encryption of personal data, the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, the ability to restore the availability of personal data and access to it in a timely manner in the event of a physical or technical incident, and regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing. According to Article 32(2) of Regulation 2016/679, when assessing whether the level of security is appropriate, the controller takes into account, in particular, the risks associated with processing, especially those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed.

As indicated in Article 24(1) of Regulation 2016/679, the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying likelihood and severity are factors that the controller is obliged to consider in the process of building a data protection system, also particularly from the perspective of the other obligations specified in Article 25(1), Article 32(1), or Article 32(2) of Regulation 2016/679. The indicated provisions specify the confidentiality principle defined in Article 5(1)(f) of Regulation 2016/679, and adherence to this principle is necessary for the proper implementation of the accountability principle arising from Article 5(2) of Regulation 2016/679.

Taking into account, in particular, the scope of personal data processed by the Mayor, in order to properly fulfill the obligations imposed by the aforementioned provisions of Regulation 2016/679, the Controller was obliged to take actions ensuring an appropriate level of data protection by implementing appropriate technical and organizational measures, as well as actions aimed at optimal configuration of the operating systems used through regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure the security of data processing in the form of security tests regarding the IT infrastructure and applications. The nature and type of these actions should result from the conducted risk analysis, in which vulnerabilities related to the utilized resources and the threats arising from them should be identified, and then appropriate security measures should be determined. Incorrect estimation of the level of risk prevents the application of appropriate security measures for a given resource and increases the likelihood of its occurrence.

The gathered evidence indicates that the Mayor conducted a risk analysis both before and after the occurrence of the personal data breach. In the further part of this decision, those risks that the Controller anticipated and which are related to the subject breach will be indicated.

As indicated in the attached risk analysis conducted on (...) May 2022 (i.e., before the occurrence of the personal data breach), the Controller anticipated the risk (risk number R8), which he defined as follows: "(...) Attacks on hardware - Break-ins to devices that are not updated, improperly...

configured, outdated software

(...)". He also described the vulnerability for this risk: "(...)

Attacks on network devices and incorrectly

configured hardware or hardware operating

with factory settings. Leaving default

passwords, access to the router's configuration page

from the Internet. Lack of software

(firmware) updates results in vulnerability to breaches, data

theft, disruption of operations. An attack using

known vulnerabilities in outdated software

(...)". As justification for the security assessment,

it was indicated: "(...) information system security procedure,

penetration tests, IT support, software updates in accordance

with manufacturers' recommendations and market opinion regarding

the security and stability of new versions (...)".

The Administrator anticipated a low probability

of this risk materializing. In the risk analysis, conducted after the occurrence of the breach, the aforementioned risk was also taken into account and, as before, the Administrator anticipated a low probability of this risk materializing.

The Mayor also anticipated the risk associated with a ransomware attack (risk number R11), describing the vulnerability as follows: “(...) Ransomware - A program for encrypting files. It installs from emails or hyperlinks in emails or through visits to an infected site. There are also known cases of infection via the local network. Decryption requires payment (...)”. As justification for the security assessment, it was indicated: “(...) tests are not performed to verify the correctness of backup execution and to check the usability of created copies during a simulated restoration attempt and the launch of domain-specific software after restoration. Staff training. GDPR regulations. Antivirus and antispam systems. Proxy servers and filtering gateways: blocking traffic based on a reputation database, blocking access to specific sites (...)”. The Administrator anticipated a medium probability

of this risk materializing. After the occurrence of the personal data breach, in the case of the aforementioned risk, the Administrator made changes to the risk analysis indicating that “(...) tests are performed to verify the correctness of backup execution and to check the usability of created copies during a simulated restoration attempt and the launch of domain-specific software after restoration (...)”. As a result, there was a reduction in the anticipated level of the aforementioned risk – after the change, the Administrator anticipated a low probability of its materialization.

Furthermore, in the risk analysis conducted before the occurrence of the personal data breach, the Mayor identified a risk (risk number 21), which he defined as “Database backups,” but – as indicated by this analysis – no backup creation procedures were anticipated, regular backups of servers, applications, files, configurations were not performed, and no tests of the restoration capabilities of the backups were conducted. The probability of this risk materializing was assessed as high.

In the modified risk analysis conducted after the occurrence of the personal data breach, in the case of the threat with number R21, it was indicated that “(...) regular backups of servers/applications/files/configurations are performed, testing the restoration capabilities of the backups (...)”. Moreover, in the case of the aforementioned threat, the Administrator indicated that the probability of risk materialization had changed

and assessed it as low.

From the above, it follows that the Mayor was aware of the possibility of losing access to the processed personal data as a result of a ransomware attack. The cause of the occurrence of the personal data breach was, firstly, a poorly conducted risk analysis (especially regarding the execution of backups), and secondly, incomplete implementation of technical and organizational measures ensuring security in the process of processing personal data, which the conducted risk analysis anticipated. The effect of the above was the materialization of the risk, resulting in the breach of the security of the information system used by the Administrator for processing personal data, and subsequently the encryption of the data processed within it using malicious software.

One of the significant elements affecting the security of personal data is ensuring that the software used for processing personal data is up to date with the latest version provided by its manufacturer. Installation of the latest updates should occur promptly, as soon as they become available. This ensures that the Administrator guarantees that such software has all updates released by the manufacturer, including security updates and patches affecting security. As indicated by the submitted explanations, the personal data breach in question was caused by a ransomware attack due to the exploitation of a vulnerability present in the IT system, which was an outdated virus database of program M. Furthermore, from the submitted explanations, it follows that the Administrator, as the operating system installed on the server at the time of the occurrence of the personal data breach, was using T. It should be noted that the aforementioned system lost manufacturer support on (...) January 2020 ([https://\[...\]](https://[...])). According to the information provided on the manufacturer's website, since (...) January 2020, there have been no additional local free security updates, non-security-related updates, free technical support options, or online technical content updates.

In this context, it should be noted that the use of IT systems for processing personal data after the end of technical support by their manufacturer significantly reduces their level of security. The lack of built-in and updated security measures particularly increases the risk of infection by malicious software and attacks due to the emergence of new vulnerabilities. These systems become more susceptible to cyberattacks, including ransomware attacks that block access to data and demand a ransom for its recovery.

At this point, it is necessary to point out the inconsistencies in the explanations provided by the Mayor. In a letter dated (...) June 2022, the Administrator indicated that "(...) virus signatures are automatically updated daily on the server, and the IT specialist checks whether an update has occurred (...)". However, subsequent explanations from the Mayor contained in letters dated (...) July 2022 and (...) August 2022 indicate that the vulnerability of the IT system that was exploited to carry out the ransomware attack was an outdated virus database of program M. This means that the

Administrator did not have full control over the security of the personal data processing process.

As discussed above, prior to the occurrence of the personal data breach, the Administrator identified the risk associated with the use of outdated software (risk number R8), but despite describing the updating of software in accordance with manufacturers' recommendations and market opinions regarding the security and stability of new versions as a security measure, the Mayor did not update the software being used. Furthermore, the risk analysis conducted by the Administrator prior to the occurrence of the personal data breach did assume the updating of the antivirus program (as a security measure in the case of risk number R11 – ransomware attacks), but the Mayor disregarded the possibility of risk materialization and did not adhere to the procedures that he himself defined.

It should also be noted that the Administrator did not foresee the risk associated with using server software that had lost manufacturer support in the conducted risk analysis, and consequently, no measures to minimize this risk were specified. This clearly indicates that the Administrator, when assessing the level of security in connection with the conducted risk analysis, did not take into account all risks associated with the processing of personal data, which is required by Article 32(2) of Regulation 2016/679. This constitutes a violation by the Administrator of this provision of Regulation 2016/679.

As a result of the breach of the IT systems' security, the Mayor's data, including personal data, was encrypted, resulting in the loss of availability to the Administrator's databases. As evidenced by the collected evidence, backup copies were also encrypted. In a letter dated (...) June 2022, the Administrator indicated that "(...) the backup creation schedule was specified in (...) the Order of the Mayor of the City of Z. No. (...) dated (...) January 2019 regarding (...). The server on which the backup copies were stored failed (...). According to (...) the Order of the Mayor of the City of Z. No. (...) dated (...) January 2019 (this document was attached to the Administrator's explanations), "(...) a copy of the databases is made once a week, and it is additionally copied to another server to secure the databases [backup execution schedule] (...). Therefore, taking into account the above, i.e., the encryption of the backup copy and the failure of the server on which the backup copies were stored, the Mayor was forced to restore data also based on paper documentation. As a result, the Administrator was unable to efficiently and relatively quickly recover the encrypted data (the complete data encrypted as a result of the ransomware attack was recovered by the Mayor only in [...] August 2022) and restore their availability. Considering the date of the occurrence/start of the breach (i.e., [...] June 2022), the limitation of availability lasted almost three months.

It should also be noted that the backup creation rules applicable to the Administrator (prior to the occurrence of the personal data breach) and the practice of creating this backup did not ensure the fulfillment of the obligations arising from Article 32(1)(b) and (c) of Regulation 2016/679, i.e., the ability to ensure the continuous availability of processing systems and services and the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident. Above all, as established, database backups were made once a week, and an additional copy was made on another server. As indicated in the submitted explanations, the server on which the additional copy was to be made failed, which prevented the quick restoration of the data on it.

Appropriate changes were implemented only after the personal data breach. First and foremost, it should be emphasized that on (...) August 2022, Order No. (...) of the Mayor of the City of Z. was issued regarding the introduction of the "Instruction (...)". In the instruction mentioned above, it was indicated that it applies to "(...) IT systems used in the City Hall of Z., in which personal data is processed. The adopted by the Personal Data Administrator (ADO) for application constitutes a binding document for all employees and collaborators. The supervision of the application of this instruction is carried out by the Information Systems Administrator (ASI) designated in the Office, whose task is to manage the IT systems of the Office, including in particular those used for processing personal data, ensuring the security of personal data in IT systems, cooperating in the preparation, implementation, and compliance by employees with the system management documentation.

****INFORMATION TECHNOLOGY AND PERSONAL DATA PROTECTION****

****1. Cooperation during the risk analysis process for the managed system and ensuring the continuity of system operation.**** The discussed instruction sanctions areas of the Administrator's activities in which he has committed negligence, resulting in a breach of personal data protection. The document regulates, among other things, issues related to the principles of creating backup copies, procedures for testing copies, and antivirus protection.

****2. Backup Copies****

In the discussed document, it is indicated that "(...) for the purpose of maintaining the continuity of information systems and ensuring data integrity, backup copies of data sets are made. This task is carried out daily on working days. Emergency copies are created automatically by dedicated software every day at 15:15 - local copy, and between 8:00 and 13:00 a copy is made on an external server. Outside of the Office's working hours, according to a predetermined schedule. The schedule contains information on which resources and systems are being copied. Copies are created incrementally. Copies are sent to an external server, as well as locally and additionally to a USB drive (...)"

****3. Scope of Backup Creation****

The instruction also specifies the scope of backup creation, indicating that it includes databases located on servers, files and directories on servers, and server operating systems. According to the provisions of the aforementioned document, "(...) backup copies are tested at least once a month. This involves a test restoration of the contents of the copy on another device. The ASI prepares a note after each test. If the backup copies of the data sets are found to be unusable, the medium is to be wiped of data or destroyed according to the data medium destruction procedure (...)"

****4. Antivirus Protection****

The instruction introduced by the Administrator also regulates the issue of antivirus protection, indicating among other things that "(...) the identified areas of the Office's information systems exposed to virus interference and other harmful software include hard drives or memory cards, electronic devices, information carriers, access to the public network, email (...). The route for the entry of viruses or harmful software may be the public network, local network, or electronic information carriers (...) workstations, laptops, and servers must be protected in real-time using antivirus software and firewall, ensuring the integrity of resources stored and processed in the Office's information system (...) the configuration of the antivirus program ensures continuous monitoring of received and sent, as well as executed files for the presence of malicious software (...)"

****5. Risk Management****

It should be noted that Regulation 2016/679 introduced an approach in which risk management forms the foundation of actions related to personal data protection. Risk management is a continuous process that requires the data administrator not only to ensure compliance with the provisions of Regulation 2016/679 through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and accountability regarding the level and adequacy of the implemented safeguards. Therefore, it becomes necessary to demonstrate to the supervisory authority that the solutions implemented to ensure the security of personal data are adequate to the level of risk and also take into account the nature of the organization and the mechanisms used for processing personal data. The Administrator must independently conduct a detailed analysis of the data processing processes and assess the risk, and then apply such measures and procedures that will be adequate to the estimated risk.

****6. Security Measures****

The consequence of such an approach is the necessity of independently selecting safeguards based on a threat analysis. Administrators are not provided with specific measures and procedures regarding security. Conducting a detailed analysis of the data processing processes and assessing the risk is the obligation of the Administrator, who should then, based on such analysis, apply measures and procedures that will be adequate to the estimated risk.

****7. Evidence of Inadequate Security Measures****

The collected evidence clearly indicates that the technical and organizational measures implemented

by the Mayor prior to the breach of personal data protection did not ensure an adequate level of security for data processed through information systems. This resulted in the failure of security mechanisms to function. In light of the above, it must be stated that the Mayor did not implement technical and organizational measures during the processing of personal data to ensure that this processing was carried out in accordance with Regulation 2016/679 and to provide the necessary safeguards for processing, as required by Article 24(1) and Article 25(1) of Regulation 2016/679. Furthermore, he did not apply technical and organizational measures ensuring a level of security corresponding to the risk of infringement of the rights or freedoms of natural persons by ensuring the ability to continuously ensure confidentiality, integrity, availability, and resilience of processing systems and services, as required by Article 32(1)(b) of Regulation 2016/679, the ability to quickly restore the availability of personal data and access to it in the event of a physical or technical incident, as stated in Article 32(1)(c) of Regulation 2016/679, and did not conduct an assessment of whether the level of security is appropriate, taking into account the risks associated with the processing of personal data, the obligation to conduct which arises from Article 32(2) of Regulation 2016/679, and consequently also violated the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679, whose aforementioned provisions are a specification. As indicated by the Provincial Administrative Court in Warsaw in the judgment of August 26, 2020, case no. II SA/Wa 2826/19, "(...) activities of a technical-organizational nature fall within the purview of the personal data controller, but they cannot be selected in a completely free and voluntary manner, without considering the degree of risk and the nature of the protected personal data (...)". Consequently, a violation by the Administrator of the principle of confidentiality results in a breach of the principle of accountability, as referred to in Article 5(2) of Regulation 2016/679.

It should also be emphasized that the introduction of changes in the area of security of the information system used by the Mayor after a breach of personal data protection by the Administrator does not change the negative assessment of the supervisory authority regarding this aspect of the personal data processing process carried out by the Administrator, and only constitutes a basis for refraining from ordering the Administrator to make changes in this area to adapt the data processing operations to the requirements of Regulation 2016/679.

In response to the supervisory authority's request for written evidence of regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of personal data processed in the information systems affected by the breach, particularly regarding vulnerabilities, errors, and their possible consequences for these systems, as well as actions taken to minimize the risk of their occurrence (both before and after the occurrence of the personal data breach), the Administrator limited himself to stating that "(...) on the server, virus signatures are automatically updated daily [the IT specialist of the City Hall Z. checks whether the update has occurred] (...)" and despite the supervisory authority's request, the Administrator did not provide evidence confirming the performance of the aforementioned activities. It should be emphasized that it was the outdated virus database of the M. program that constituted the vulnerability of the information system, which was exploited to carry out the ransomware attack.

Indeed, according to the provisions contained in the list of applied organizational and technical measures to ensure high-level personal data security, which is an annex to the order no. (...) of the Mayor of the City of Z. dated (...) January 2019, the following technical measures were implemented for the proper protection of personal data: - antivirus programs are installed on all workstations, which are updated according to licensing conditions, - a system is used to monitor the status of critical services and resources (servers/databases/network devices), - central monitoring of the antivirus program's security.

However, it should be noted that the adopted technical measures intended for the proper protection of personal data were in no way tested, measured, and assessed by the Mayor to verify their effectiveness (alternatively: the Administrator, despite the supervisory authority's request, did not present – in accordance with the principle of accountability referred to in Article 5(2) of Regulation 2016/679 – any evidence confirming the performance of such tests). Confirmation of the above is also

the manner in which the vulnerability of the information system was exploited to carry out the ransomware attack.

Consequently, it should be noted that the lack of testing determines that the Administrator did not fulfill his obligations arising from Article 32(1)(d) of Regulation 2016/679. The technical and organizational safeguards concerning the information systems used for processing personal data were not subjected to testing. In this regard, the Mayor was unable to demonstrate or ascertain that the applied security measures possess the characteristics of sufficiency. The indicated testing, measuring, and assessing, to constitute the fulfillment of the requirement resulting from Article 32(1)(d) of Regulation 2016/679, must be conducted regularly, which means consciously planning and organizing, as well as documenting (in connection with the principle of accountability referred to in Article 5(2) of Regulation 2016/679) such activities within specified time intervals, regardless of changes in the organization and the course of data processing processes.

It is worth emphasizing that regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of processing is a fundamental obligation of every controller and processor arising from Article 32(1)(d) of Regulation 2016/679. The Administrator is therefore obliged to verify both the selection and the level of effectiveness of the technical measures used at every stage of processing. The complexity of this verification should be assessed in terms of adequacy to risks and proportionality concerning the state of technical knowledge, implementation costs, as well as the nature, scope, context, and purposes of processing. However, in the present factual state, it should be concluded that the Administrator did not duly fulfill the obligation imposed on him regarding testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of personal data processing. Furthermore, the Administrator did not provide evidence that after the occurrence of the personal data breach, he conducts regular testing, measuring, and assessing the effectiveness of technical and organizational measures to ensure the security of personal data processed in information systems. It should be noted in passing that introduced after the occurrence of a breach, the "Instruction (...)" does not provide for regular testing, measuring, and assessing the effectiveness of technical and organizational measures aimed at ensuring the security of personal data processing. According to the aforementioned document, only backup copies of personal data are subject to testing, which does not exhaust the Administrator's obligations in this regard and determines the necessity of recognizing a breach of the requirement arising from Article 32(1)(d) of Regulation 2016/679. The position of the supervisory authority on the matter discussed above is not altered by the statement of the Administrator contained in the letter dated (...) March 2023 (cf. point 5 of the factual justification), in which it was indicated, among other things, that (...) as part of regular testing, measuring, and assessing the effectiveness of technical and organizational measures aimed at ensuring processing security, cyclical audits and risk analyses are conducted (...). The above statement by the Mayor has not been supported by evidence, which the Administrator had already been called upon to provide. In this context, it must be emphasized once again that testing, measuring, and assessing the effectiveness of the adopted security measures must also be documented (in connection with the principle of accountability referred to in Article 5(2) of Regulation 2016/679) – meanwhile, the Mayor at no stage of the administrative proceedings, despite the supervisory authority's request, presented evidence in this regard, limiting himself only to the statement that he conducts "cyclical audits and risk analyses." In light of the above, the statement of the Administrator contained in the aforementioned letter was deemed insufficient by the President of the Personal Data Protection Office.

In light of the findings made during this proceeding, it should be pointed out that the Mayor, by not applying technical and organizational measures ensuring the security of processed data, which resulted in a breach of personal data protection reported to the President of the Personal Data Protection Office on (...) June 2022, violated Article 5(1)(f) of Regulation 2016/679, reflected in the obligations specified in Article 24(1), Article 25(1), Article 32(1), and Article 32(2). The consequence of violating Article 5(1)(f) of Regulation 2016/679 is a breach of the accountability principle expressed in Article 5(2) of Regulation 2016/679. As stated in the judgment of the Administrative Court in Warsaw

dated February 10, 2021, case reference II SA/Wa 2378/20, "The principle of accountability is based on the legal responsibility of the administrator for properly fulfilling obligations and imposes on them the duty to demonstrate, both before the supervisory authority and before the data subject, evidence of compliance with all data processing principles." Similarly, the issue of the accountability principle is interpreted by the Administrative Court in Warsaw in the judgment dated August 26, 2020, case reference II SA/Wa 2826/19, "Considering the entirety of the norms of Regulation 2016/679, it should be emphasized that the administrator has considerable freedom regarding the security measures applied; however, they are also responsible for violating data protection regulations. The principle of accountability directly implies that it is the data administrator who should demonstrate, and thus prove, that they comply with the provisions specified in Article 5(1) of Regulation 2016/679."

Taking the above into account, as well as the content of Article 58(2)(d) of Regulation 2016/679, the President of the Personal Data Protection Office ordered the administrator to adapt processing operations to the provisions of Regulation 2016/679 by implementing technical and organizational measures to ensure regular testing, measuring, and assessing the effectiveness of technical and organizational measures aimed at ensuring processing security. Based on Article 58(2)(i) of Regulation 2016/679, each supervisory authority has the power to impose, in addition to or instead of other corrective measures provided for in Article 58(2)(a) - (h) and (j) of this regulation, an administrative monetary penalty under Article 83 of Regulation 2016/679, depending on the circumstances of the specific case. Considering the factual findings, the President of the Personal Data Protection Office, exercising the authority granted to him under the aforementioned provision of Regulation 2016/679, determined that in the case at hand, there were grounds justifying the imposition of an administrative monetary penalty on the Mayor of City Z.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the administrator and the processor, referred to in Articles 8, 11, 25 - 39, as well as 42 and 43, are subject to an administrative monetary penalty of up to EUR 10,000,000, and in the case of an enterprise, up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying. According to Article 83(5)(a) of Regulation 2016/679, violations of the provisions concerning the basic principles of processing, including the conditions for consent, referred to in Articles 5, 6, 7, and 9, are subject to an administrative monetary penalty of up to EUR 20,000,000, and in the case of an enterprise, up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying. Article 83(3) of Regulation 2016/679 states that if the administrator or processor intentionally or unintentionally violates several provisions of this regulation within the same or related processing operations, the total amount of the administrative monetary penalty shall not exceed the amount of the penalty for the most serious violation.

In this case, the administrative monetary penalty imposed on the Mayor was for the violation of Article 25 para. 1 and Article 32 para. 1 and 2 of Regulation 2016/679 based on the aforementioned Article 83 para. 4 lit. a) of Regulation 2016/679, while for the violation of Article 5 para. 1 lit. f) and Article 5 para. 2 of Regulation 2016/679 - based on Article 83 para. 5 lit. a) of that regulation. At the same time, the penalty imposed on the Mayor for the violation of all the above provisions - in accordance with Article 83 para. 3 of Regulation 2016/679 - does not exceed the amount of the penalty for the most serious violation identified in this case, namely the violation of Article 5 para. 1 lit. f) and Article 5 para. 2 of Regulation 2016/679, which in accordance with Article 83 para. 5 lit. a) of Regulation 2016/679 is subject to an administrative fine of up to 20,000,000 EUR, and in the case of an enterprise - up to 4% of its total annual worldwide turnover from the previous financial year. In deciding to impose an administrative fine, the President of the UODO - in accordance with the provisions of Article 83 para. 2 lit. a) - k) of Regulation 2016/679 - took into account the following circumstances of the case, which necessitate the application of this type of sanction in this case and which have an aggravating effect on the amount of the imposed administrative fine:

1. The nature, gravity, and duration of the violation, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83 para. 2 lit. a) of Regulation 2016/679). The violation of personal

data protection regulations identified in this case, which resulted in the loss of availability of data processed by the Mayor, which occurred as a result of a ransomware attack, is of significant weight and serious nature, as it created a high risk of negative legal consequences for an undetermined, potentially large number of individuals (the Administrator indicated that the data breach concerns approximately 9,400 individuals). Although the Administrator did not establish a breach of data confidentiality, indicating that "(...) it is likely that there was no loss of confidentiality of personal data, but as of the date of the response, he was unable to confirm this (...)", due to the Administrator's inability to demonstrate (in accordance with the principle of accountability) the exclusion of this type of violation, it must be assumed that there is a risk that a loss of data confidentiality may have occurred. It should be noted that malware can contribute to a breach of data confidentiality as a result of sending personal data outside the Administrator's organization over an extended period in the form of small data packets, in such a way that the increase in network traffic goes unnoticed. Moreover, the ransomware attack could have occurred only after the personal data had been transmitted outside the Administrator's organization. The Mayor, due to the solutions he adopted, is unable to demonstrate (in accordance with the principle of accountability referred to in Article 5 para. 2 of Regulation 2016/679) that the confidentiality of the personal data processed by him was not breached.

The Mayor's violation of the obligation to implement security measures to protect processed data from being disclosed to unauthorized persons entails not only a potential but also a real possibility of these data being used by third parties without the knowledge and against the will of the individuals whose data is concerned, in violation of the provisions of Regulation 2016/679, e.g., for the purpose of establishing legal relations or incurring obligations on behalf of the individuals whose data was obtained. It should be emphasized that the Mayor, as an executive body of the local government (municipality), is a subject of public trust, and it is expected that he is familiar with the regulations and applies them properly, thus maintaining high standards regarding the security of processed data.

At the same time, it should be noted that the Administrator (as indicated in the explanations provided by him) recovered all encrypted data only on (...) August 2022. This means that the Mayor lost access to the personal data he processed in connection with the tasks entrusted to him for the period from (...) June 2022 to (...) August 2022. In this case, there is no evidence that individuals whose data could have been accessed by unauthorized persons suffered any material damage. Nevertheless, the mere breach of confidentiality of their data constitutes a non-material damage (harm); individuals whose data was unlawfully obtained may at least feel anxiety about losing control over their personal data, identity theft, or identity fraud, discrimination, or finally, financial loss. Even assuming that there was no loss of data confidentiality, it should be taken into account that the Mayor lost full access to the personal data he processed in connection with the performance of the tasks entrusted to him. Therefore, it should be assumed that there was a risk of being unable to address the matters of specific individuals (whose data was breached) within the time limits provided for in separate regulations, i.e., the Mayor, instead of fulfilling his tasks within the statutory deadlines, using the processed personal data (to which he lost access as a result of the breach), had to first regain access to them.

Furthermore, public notification of individuals does not guarantee that the information reached every person to whom it should have reached. Thus, there may have been situations where individuals affected by the breach, lacking knowledge of the breach, may not have taken actions to ensure at least a minimum sense of security by increasing caution in handling their personal data.

2. The unintentional nature of the violation (Article 83 para. 2 lit. b of Regulation 2016/679). The Administrator was aware that in the case of allowing the processing... of personal data in information systems, must process personal data in such a way as to ensure their appropriate security, including protection against potential malware attacks, thus ensuring compliance with the principle of "integrity and confidentiality" expressed in Article 5(1)(f) of Regulation 2016/679. The Mayor, due to the scope of the activities of the Office he manages, was aware of the possibility of a breach of personal data protection as a result of a ransomware attack, as evidenced by the risk analysis conducted.

It should be emphasized that the significant impact on the occurrence of the breach in question was the gross negligence of the local government authority. Despite being aware of the threat to security in the process of processing personal data related to the likelihood of a ransomware attack, the Mayor acted in a negligent manner regarding personal data protection. Thus, he unintentionally violated the provisions on personal data protection - Article 5(1)(f) of Regulation 2016/679 in conjunction with Article 24(1), 25(1), 32(1) and (2) of Regulation 2016/679, and consequently also Article 5(2) of Regulation 2016/679.

Considering the findings in the matter subject to the resolution of this decision, it should be stated that the Administrator committed negligence resulting in a breach of personal data protection, which occurred as a result of, among other things, gross negligence and unreliability of the local government authority. Thus, this constitutes a significant circumstance affecting the severity of the administrative monetary penalty.

3. Categories of personal data affected by the breach (Article 83(2)(g) of Regulation 2016/679). The personal data contained in the resources of the Mayor, to which he lost access as a result of the ransomware attack, did not belong to special categories of personal data referred to in Article 9 of Regulation 2016/679; however, their scope, i.e., surnames and first names, parents' names, date of birth, bank account number, address of residence or stay, PESEL identification number, email address, data regarding earnings and/or owned assets, maiden name of the mother, phone number, image, is associated with a high risk of infringement of the rights or freedoms of the individuals affected by the breach. It should be emphasized that in particular, the fact that the breach involved personal data such as the PESEL identification number along with the first name and surname, which unequivocally identify an individual, can realistically and negatively affect the protection of the rights or freedoms of that person. It should be noted that the PESEL identification number, which is an eleven-digit numerical symbol that unequivocally identifies an individual, containing, among other things, the date of birth and gender designation, and thus closely related to the private sphere of the individual and also subject to, as a national identification number, exceptional protection under Article 87 of Regulation 2016/679, is data of a special nature and requires such special protection.

In determining the amount of the administrative monetary penalty, the President of the UODO considered as a mitigating circumstance, which influenced the reduction of the imposed penalty, the good cooperation of the Administrator with the supervisory authority undertaken and conducted in order to eliminate the breach and mitigate its potential negative effects [Article 83(2)(f) of Regulation 2016/679]. It should be noted that beyond properly fulfilling the procedural obligations imposed on the Mayor during the administrative proceedings, which concluded with the issuance of this decision, the Mayor fully implemented the recommendations of the President of the UODO regarding the supplementation of the notification to the individuals concerned about the breach that occurred.

The fact that the President of the UODO applied a sanction in the form of an administrative monetary penalty against the Mayor in this case, as well as its amount, was not influenced by other circumstances indicated in Article 83(2) of Regulation 2016/679, namely:

1. Actions taken to minimize the damage suffered by the individuals concerned (Article 83(2)(c) of Regulation 2016/679). The actions of the Administrator in this regard were limited solely to notifying individuals about the breach through a public announcement made available on the Administrator's website. However, this announcement constitutes only the fulfillment of a legal obligation arising from Article 34(3)(c) of Regulation 2016/679, and as stated in Guidelines WP 253 (regarding the criterion of "the manner in which the supervisory authority became aware of the breach"), "[t]he mere fulfillment [...] of the obligation by the administrator cannot be interpreted as a mitigating factor."

2. The degree of responsibility of the administrator taking into account the technical and organizational measures implemented by him under Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). In the Guidelines adopted on October 3, 2017, by the Article 29 Working Party on the application and determination of administrative monetary penalties for the purposes of Regulation No. 2016/679, it was indicated that - when considering this criterion - "the supervisory authority must answer the question of

to what extent the administrator, considering the nature, purposes, or scope of processing and in light of the obligations imposed on him by the regulation."

The President of the UODO stated in this case that the Mayor violated the provisions of Articles 25(1), 32(1) and (2) of Regulation 2016/679. In his opinion, the administrator bears a high degree of responsibility for the failure to implement appropriate measures.

technical and organizational measures that would prevent violations of personal data protection. It is obvious that in the context of the nature, purpose, and scope of personal data processing, the Administrator did not "do everything that could have been expected of him"; thus, he failed to comply with the obligations imposed on him by Articles 25 and 32 of Regulation 2016/679.

In this case, this circumstance constitutes the essence of the violation of the provisions of Regulation 2016/679; it is not merely a factor influencing - either mitigating or aggravating - its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Articles 25 and 32 of Regulation 2016/679 cannot be considered by the President of UODO in this case as a circumstance that could additionally influence a harsher assessment of the violation and the amount of the administrative fine imposed on the Mayor.

3. Any relevant prior violations by the administrator or the processor (Article 83(2)(e) of Regulation 2016/679). The President of UODO did not find any prior violations of personal data protection regulations committed by the Administrator, which means there are no grounds to treat this circumstance as aggravating. It is the duty of every administrator to comply with the law (including personal data protection regulations), so the lack of prior violations cannot be a mitigating circumstance when imposing sanctions.

4. The manner in which the supervisory authority became aware of the violation (Article 83(2)(h) of Regulation 2016/679). The President of UODO identified the violation of the provisions of Regulation 2016/679 as a result of a report of a personal data breach made by the Administrator. By making this report, the Administrator was merely fulfilling a legal obligation, and there are no grounds to consider this circumstance as mitigating. According to the Guidelines on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 WP 253, "The supervisory authority may become aware of a violation as a result of proceedings, complaints, articles in the press, anonymous tips, or notification by the data controller. According to the regulation, the controller has an obligation to notify the supervisory authority of a personal data breach. The mere fulfillment of this obligation by the controller cannot be interpreted as a mitigating factor."

5. Compliance with previously applied measures in the same case, as referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Before issuing this decision, the President of UODO did not apply any of the measures listed in Article 58(2) of Regulation 2016/679 against the Administrator in the case at hand, which means that the administrator had no obligation to take any actions related to their application, and such actions, assessed by the President of UODO, could have had an aggravating or mitigating impact on the assessment of the identified violation.

6. The application of approved codes of conduct under Article 40 of Regulation 2016/679 or approved certification mechanisms under Article 42 of Regulation 2016/679 (Article 83(2)(j) of Regulation 2016/679). The Mayor does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not - as stated in the provisions of Regulation 2016/679 - mandatory for controllers and processors, which means that the circumstance of their non-application cannot be considered against the Administrator in this case. On the other hand, the circumstance of adopting and applying such instruments as measures guaranteeing a higher than standard level of protection for processed personal data could be taken into account in favor of the Administrator.

7. Financial benefits obtained directly or indirectly in connection with the violation or avoided losses (Article 83(2)(k) of Regulation 2016/679). The President of UODO did not find that the administrator obtained any financial benefits or avoided such losses in connection with the violation. Therefore, there are no grounds to treat this circumstance as aggravating for the administrator. The existence of

measurable financial benefits resulting from the violation of the provisions of Regulation 2016/679 should be assessed very negatively. On the other hand, the administrator's failure to achieve such benefits, as a natural state independent of the violation and its effects, is a circumstance that cannot inherently be mitigating for the Administrator. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "obtained" - that is, those that occurred on the part of the entity committing the violation.

8. Other aggravating or mitigating factors (Article 83(2)(k) of Regulation 2016/679). The President of UODO, comprehensively examining the case, did not note any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed administrative fine.

Considering all the circumstances discussed above, the President of the Personal Data Protection Office concluded that imposing an administrative fine on the Mayor is necessary and justified given the weight, nature, and scope of the violations attributed to the Mayor. It should be stated that applying any other corrective measure provided for in Article 58(2) of Regulation 2016/679, especially merely issuing a reprimand (Article 58(2)(b)), would not be proportional to the identified irregularities. in the process of processing personal data and would not guarantee that the Administrator would not commit further negligence in the future. Referring to the amount of the administrative fine imposed on the Mayor, the President of the UODO concluded that in the established circumstances of this case – i.e., in light of the determination of violations of several provisions of Regulation 2016/679 (principles of data confidentiality, expressed in Article 5(1)(f), as reflected in the obligations specified in Article 25(1) and Article 32(1) and (2) of Regulation 2016/679, and consequently also Article 5(2) of Regulation 2016/679 (principle of accountability) and the fact that the Mayor is an authority of a public finance sector entity – Article 102(1)(1) of the Act of May 10, 2018, on the protection of personal data (Journal of Laws of 2019, item 1781) applies, which results in a limitation of the amount (to 100,000 PLN) of the administrative fine that may be imposed on a public finance sector entity.

In the opinion of the President of the UODO, the administrative fine imposed is effective, proportional, and deterrent in the established circumstances of this case, as referred to in Article 83(1) of Regulation 2016/679. The President of the UODO believes that the fine imposed on the Mayor will be effective, as it will lead to a situation in which the Mayor will implement such technical and organizational measures that ensure a level of security for the processed data corresponding to the risk of infringement of the rights or freedoms of the data subjects and the severity of the threats associated with the processing of such personal data. Therefore, the effectiveness of the fine is equivalent to the guarantee that the Mayor, from the moment of the conclusion of this proceeding, will approach the requirements set by the data protection regulations with the utmost diligence.

The imposed administrative fine is also proportional to the established violation, especially regarding its severity, effect, the scope of affected individuals, and the high risk of negative consequences that may arise from the violation. In the opinion of the President of the UODO, the administrative fine imposed on the Mayor will not constitute an excessive burden for him. The amount of the fine has been set at a level that, on the one hand, constitutes an adequate response from the supervisory authority to the degree of violation of the administrator's obligations, and on the other hand, does not create a situation in which the necessity to pay it would lead to negative consequences in the form of a significant deterioration of the Administrator's financial situation. According to the President of the UODO, the Mayor should and is capable of bearing the consequences of his negligence in the area of data protection, hence the imposition of a fine in the amount of 30,000 PLN (thirty thousand zlotys) is fully justified.

In the opinion of the President of the UODO, the administrative fine will serve a repressive function in these specific circumstances, as it will respond to the Mayor's violation of the provisions of Regulation 2016/679, but it will also serve a preventive function, as it will contribute to preventing future violations of the Administrator's obligations arising from data protection regulations.

In the opinion of the President of the UODO, the administrative fine imposed meets the criteria set out

in Article 83(1) of Regulation 2016/679 due to the severity of the established violations in the context of the fundamental requirements and principles of Regulation 2016/679 – especially the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679. The purpose of the imposed fine is to ensure that the Mayor complies with the provisions of Regulation 2016/679 in the future.

In this factual and legal situation, the President of the Office for Personal Data Protection has decided as stated in the ruling.

Print article

Metadata

Entity providing the information:

Department of Control and Violations

Created by:

Jan Nowak

2023-05-16

Entered by:

Wioletta Golańska

2023-06-05 14:28:02

Last modified by:

Edyta Madziar

2023-06-27 09:59:06